

# Network Security

## Network Security Concepts

---

# Current State of Affairs

Maintaining a secure network ensures the safety of network users and protects commercial interests. All users should be aware of the following security terms.

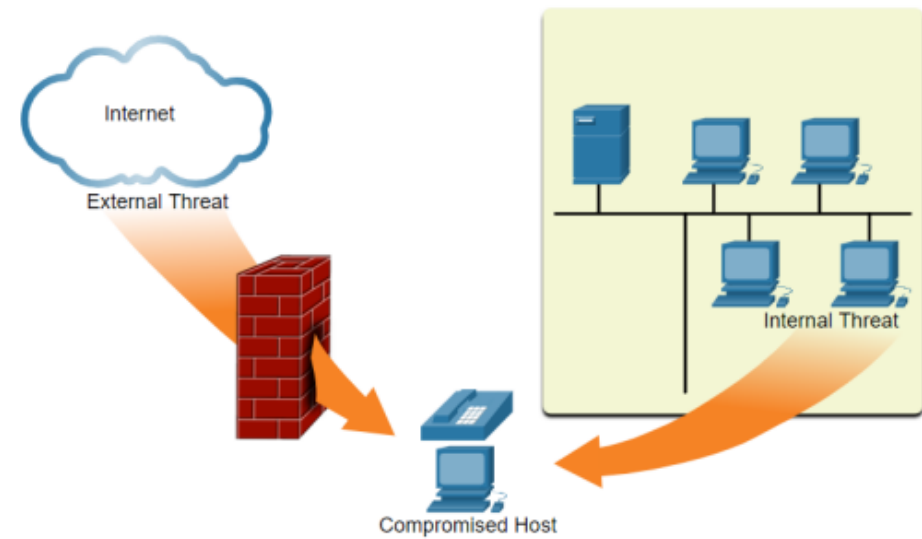
| Security Terms       | Description                                                                                                                                                                                                                   |
|----------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Assets</b>        | An asset is anything of value to the organization. It includes people, equipment, resources, and data.                                                                                                                        |
| <b>Vulnerability</b> | A vulnerability is a weakness in a system, or its design, that could be exploited by a threat.                                                                                                                                |
| <b>Threat</b>        | A threat is a potential danger to a company's assets, data, or network functionality.                                                                                                                                         |
| <b>Exploit</b>       | An exploit is a mechanism that takes advantage of a vulnerability.                                                                                                                                                            |
| <b>Mitigation</b>    | Mitigation is the counter-measure that reduces the likelihood or severity of a potential threat or risk. Network security involves multiple mitigation techniques.                                                            |
| <b>Risk</b>          | Risk is the likelihood of a threat to exploit the vulnerability of an asset, with the aim of negatively affecting an organization. Risk is measured using the probability of the occurrence of an event and its consequences. |

---

# Current State of Affairs

## Vectors of Network Attacks

- An attack vector is a path by which a threat actor can gain access to a server, host, or network. Attack vectors originate from inside or outside the corporate network.
- Internal threats have the potential to cause greater damage than external threats because internal users have direct access to the building and its infrastructure devices.



# Data Loss

Data loss or data exfiltration is when data is intentionally or unintentionally lost, stolen, or leaked to the outside world. The data loss can result in:

- Brand damage and loss of reputation
  - Loss of competitive advantage
  - Loss of customers
  - Loss of revenue
  - Litigation/legal action resulting in fines and civil penalties
  - Significant cost and effort to notify affected parties and recover from the breach
-

# Data Loss Vectors

| Data Loss Vectors       | Description                                                                                                                                                                    |
|-------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Email/Social Networking | Intercepted email or IM messages could be captured and reveal confidential information.                                                                                        |
| Unencrypted Devices     | If the data is not stored using an encryption algorithm, then the thief can retrieve valuable confidential data.                                                               |
| Cloud Storage Devices   | Sensitive data can be lost if access to the cloud is compromised due to weak security settings.                                                                                |
| Removable Media         | One risk is that an employee could perform an unauthorized transfer of data to a USB drive. Another risk is that a USB drive containing valuable corporate data could be lost. |
| Hard Copy               | Confidential data should be shredded when no longer required.                                                                                                                  |
| Improper Access Control | Passwords or weak passwords which have been compromised can provide a threat actor with easy access to corporate data.                                                         |

---

# Threat Actors

## The Hacker

Hacker is a common term used to describe a threat actor

| Hacker Type       | Description                                                                                                                                                                                                                                |
|-------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| White Hat Hackers | These are ethical hackers who use their programming skills for good, ethical, and legal purposes. Security vulnerabilities are reported to developers for them to fix before the vulnerabilities can be exploited.                         |
| Gray Hat Hackers  | These are individuals who commit crimes and do arguably unethical things, but not for personal gain or to cause damage. Gray hat hackers may disclose a vulnerability to the affected organization after having compromised their network. |
| Black Hat Hackers | These are unethical criminals who compromise computer and network security for personal gain, or for malicious reasons, such as attacking networks.                                                                                        |

---

# Modern Hacking Terms

| Hacking Term                | Description                                                                                                                                                                                                                                                                            |
|-----------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| <b>Script Kiddies</b>       | These are teenagers or inexperienced hackers running existing scripts, tools, and exploits, to cause harm, but typically not for profit.                                                                                                                                               |
| <b>Vulnerability Broker</b> | These are usually gray hat hackers who attempt to discover exploits and report them to vendors, sometimes for prizes or rewards.                                                                                                                                                       |
| <b>Hacktivists</b>          | These are gray hat hackers who publicly protest organizations or governments by posting articles, videos, leaking sensitive information, and performing network attacks.                                                                                                               |
| <b>Cyber criminals</b>      | These are black hat hackers who are either self-employed or working for large cybercrime organizations.                                                                                                                                                                                |
| <b>State-Sponsored</b>      | These are either white hat or black hat hackers who steal government secrets, gather intelligence, and sabotage networks. Their targets are foreign governments, terrorist groups, and corporations. Most countries in the world participate to some degree in state-sponsored hacking |



# Threat Actor Tools

The table highlights categories of common penetration testing tools. Some tools are used by white and black hats. Keep in mind that the list is not exhaustive as new tools are always being developed.

| Penetration Testing Tool           | Description                                                                                                                                                                                                                                                                                                                 |
|------------------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Password Crackers                  | Password cracking tools are often referred to as password recovery tools and can be used to crack or recover a password. Password crackers repeatedly make guesses in order to crack the password. Examples of password cracking tools include John the Ripper, Ophcrack, L0phtCrack, THC Hydra, Rainbow Crack, and Medusa. |
| Wireless Hacking Tools             | Wireless hacking tools are used to intentionally hack into a wireless network to detect security vulnerabilities. Examples of wireless hacking tools include Aircrack-ng, Kismet, InSSIDer, KisMAC, Firesheep, and WiStumbler.                                                                                              |
| Network Scanning and Hacking Tools | Network scanning tools are used to probe network devices, servers, and hosts for open TCP or UDP ports. Examples of scanning tools include Nmap, SuperScan, Angry IP Scanner, and NetScanTools.                                                                                                                             |
| Packet Crafting Tools              | These tools are used to probe and test a firewall's robustness using specially crafted forged packets. Examples include Hping, Scapy, Socat, Yersinia, Netcat, Nping, and Nemesis.                                                                                                                                          |
| Packet Sniffers                    | These tools are used to capture and analyze packets within traditional Ethernet LANs or WLANs. Tools include Wireshark, Tcpdump, Ettercap, Dsniff, EtherApe, Paros, Fiddler, Ratproxy, and SSLstrip.                                                                                                                        |



# Threat Actor Tools

Cont'd

| Penetration Testing Tool          | Description                                                                                                                                                                                                                                      |
|-----------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Rootkit Detectors                 | This is a directory and file integrity checker used by white hats to detect installed root kits. Example tools include AIDE, Netfilter, and PF: OpenBSD Packet Filter.                                                                           |
| Fuzzers to Search Vulnerabilities | Fuzzers are tools used by threat actors to discover a computer's security vulnerabilities. Examples of fuzzers include Skipfish, Wapiti, and W3af.                                                                                               |
| Forensic Tools                    | These tools are used by white hat hackers to sniff out any trace of evidence existing in a computer. Example of tools include Sleuth Kit, Helix, Maltego, and Encase.                                                                            |
| Debuggers                         | These tools are used by black hats to reverse engineer binary files when writing exploits. They are also used by white hats when analyzing malware. Debugging tools include GDB, WinDbg, IDA Pro, and Immunity Debugger.                         |
| Hacking Operating Systems         | These are specially designed operating systems preloaded with tools optimized for hacking. Examples of specially designed hacking operating systems include Kali Linux, BackBox Linux.                                                           |
| Encryption Tools                  | Encryption tools use algorithm schemes to encode the data to prevent unauthorized access to the encrypted data. Examples of these tools include VeraCrypt, CipherShed, OpenSSH, OpenSSL, Tor, OpenVPN, and Stunnel.                              |
| Vulnerability Exploitation Tools  | These tools identify whether a remote host is vulnerable to a security attack. Examples of vulnerability exploitation tools include Metasploit, Core Impact, Sqlmap, Social Engineer Toolkit, and Netsparker.                                    |
| Vulnerability Scanners            | These tools scan a network or system to identify open ports. They can also be used to scan for known vulnerabilities and scan VMs, BYOD devices, and client databases. Examples of tools include Nipper, Core Impact, Nessus, SAINT, and OpenVAS |

---

# Most Common Attack Types

| Attack Type              | Description                                                                                                                                                                                                                                                                                                                   |
|--------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Malware                  | Malware is a term used to describe malicious software, including spyware, ransomware, viruses, and worms. Malware breaches a network through a vulnerability, typically when a user clicks a dangerous link or email attachment that then installs risky software.                                                            |
| Phishing                 | Phishing is the practice of sending fraudulent communications that appear to come from a reputable source, usually through email. The goal is to steal sensitive data like credit card and login information or to install malware on the victim's machine. Phishing is an increasingly common cyberthreat.                   |
| Man-in-the-middle (MITM) | Man-in-the-middle (MitM) attacks, also known as eavesdropping attacks, occur when attackers insert themselves into a two-party transaction. Once the attackers interrupt the traffic, they can filter and steal data                                                                                                          |
| Denial-of-service (DoS)  | A denial-of-service attack floods systems, servers, or networks with traffic to exhaust resources and bandwidth. As a result, the system is unable to fulfill legitimate requests. Attackers can also use multiple compromised devices to launch this attack. This is known as a distributed-denial-of-service (DDoS) attack. |
| SQL injection            | A Structured Query Language (SQL) injection occurs when an attacker inserts malicious code into a server that uses SQL and forces the server to reveal information it normally would not. An attacker could carry out a SQL injection simply by submitting malicious code into a vulnerable website search box                |

# Most Common Attack Types

Cont'd

| Attack Type              | Description                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                          |
|--------------------------|----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Zero-day exploit         | A zero-day exploit hits after a network vulnerability is announced but before a patch or solution is implemented. Attackers target the disclosed vulnerability during this window of time. Zero-day vulnerability threat detection requires constant awareness.                                                                                                                                                                                                                                                                                                                                                                                                      |
| DNS Tunneling            | DNS tunneling utilizes the DNS protocol to communicate non-DNS traffic over port 53. It sends HTTP and other protocol traffic over DNS. There are various, legitimate reasons to utilize DNS tunneling. However, there are also malicious reasons to use DNS Tunneling VPN services. They can be used to disguise outbound traffic as DNS, concealing data that is typically shared through an internet connection. For malicious use, DNS requests are manipulated to exfiltrate data from a compromised system to the attacker's infrastructure. It can also be used for command and control callbacks from the attacker's infrastructure to a compromised system. |
| Eavesdropping Attack     | This is when a threat actor captures and "listens" to network traffic. This attack is also referred to as sniffing or snooping.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                      |
| Data Modification Attack | If threat actors have captured enterprise traffic, they can alter the data in the packet without the knowledge of the sender or receiver.                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                            |

---

# Most Common Attack Types

Cont'd

| Attack Type                | Description                                                                                                                                                                                                                                                                             |
|----------------------------|-----------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| IP Address Spoofing Attack | A threat actor constructs an IP packet that appears to originate from a valid address inside the corporate intranet.                                                                                                                                                                    |
| Password-Based Attacks     | If threat actors discover a valid user account, the threat actors have the same rights as the real user. Threat actors could use that valid account to obtain lists of other users, network information, change server and network configurations, and modify, reroute, or delete data. |
| Compromised-Key            | Attack If a threat actor obtains a secret key, that key is referred to as a compromised key. A compromised key can be used to gain access to a secured communication without the sender or receiver being aware of the attack.                                                          |
| Sniffer Attack             | A sniffer is an application or device that can read, monitor, and capture network data exchanges and read network packets. If the packets are not encrypted, a sniffer provides a full view of the data inside the packet.                                                              |

---



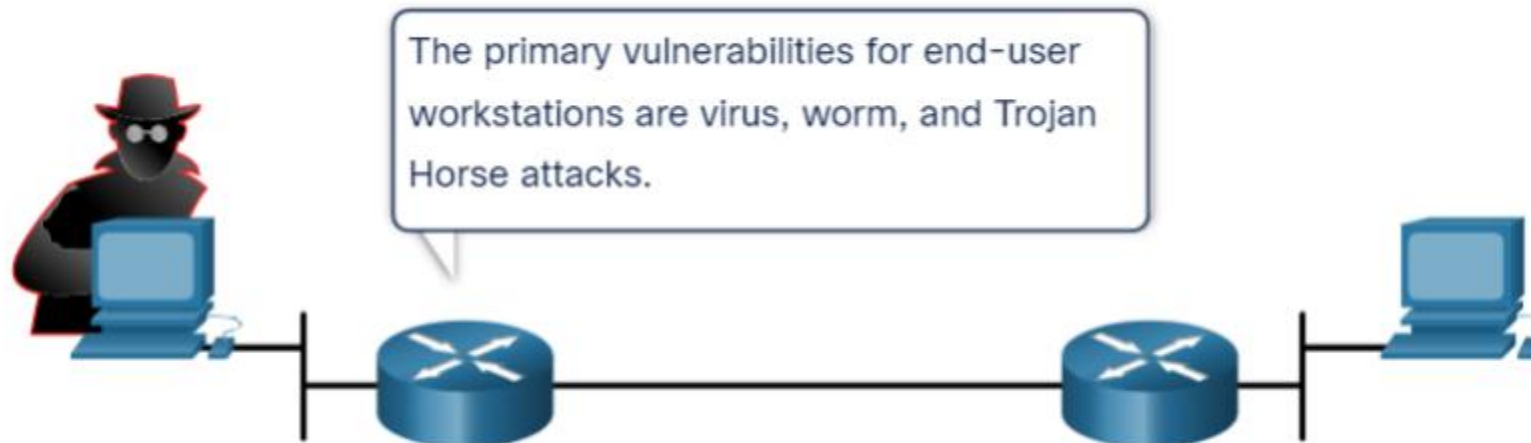
Malware

Malware

---

# Malware Overview

It is important to know about malware because threat actors rely on users to install malware to help exploit the security gaps.



# Virus

A Virus requires human action to propagate and infect other computers.

A Virus hides by attaching itself to computer code, software, or documents on the computer.

Viruses are developed for specific intent such as those listed in the table.

| Types of Viruses  | Description                                                          |
|-------------------|----------------------------------------------------------------------|
| Boot sector virus | Virus attacks the boot sector, file partition table, or file system. |
| Firmware viruses  | Virus attacks the device firmware.                                   |
| Macro virus       | Virus uses the MS Office macro feature maliciously.                  |
| Program viruses   | Virus inserts itself in another executable program.                  |
| Script viruses    | Virus attacks the OS interpreter which is used to execute scripts.   |

---



# Trojan Horses

A Trojan horse is a program that looks useful but also carries malicious code.

Trojan horses are often provided with free online programs such as computer games.

| Type of Trojan Horse       | Description                                                                                                                                      |
|----------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------|
| Remote-access              | Trojan horse enables unauthorized remote access.                                                                                                 |
| Data-sending               | Trojan horse provides the threat actor with sensitive data, such as passwords.                                                                   |
| Destructive                | Trojan horse corrupts or deletes files.                                                                                                          |
| Proxy                      | Trojan horse will use the victim's computer as the source device to launch attacks and perform other illegal activities.                         |
| FTP                        | Trojan horse enables unauthorized file transfer services on end devices.                                                                         |
| Security software disabler | Trojan horse stops antivirus programs or firewalls from functioning.                                                                             |
| Denial of Service (DoS)    | Trojan horse slows or halts network activity.                                                                                                    |
| Keylogger                  | Trojan horse actively attempts to steal confidential information, such as credit card numbers, by recording key strokes entered into a web form. |

---

# Other Types of Malware

| Malware    | Description                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                                 |
|------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Adware     | <ul style="list-style-type: none"><li>•Adware is usually distributed by downloading online software.</li><li>•Adware can display unsolicited advertising using pop-up web browser windows, new toolbars, or unexpectedly redirect a webpage to a different website.</li><li>•Pop-up windows may be difficult to control as new windows can pop-up faster than the user can close them.</li></ul>                                                                                                                                                                                                            |
| Ransomware | <ul style="list-style-type: none"><li>•Ransomware typically denies a user access to their files by encrypting the files and then displaying a message demanding a ransom for the decryption key.</li><li>•Users without up-to-date backups must pay the ransom to decrypt their files.</li><li>•Payment is usually made using wire transfer or crypto currencies such as Bitcoin.</li></ul>                                                                                                                                                                                                                 |
| Rootkit    | <ul style="list-style-type: none"><li>•Rootkits are used by threat actors to gain administrator account-level access to a computer.</li><li>•They are very difficult to detect because they can alter firewall, antivirus protection, system files, and even OS commands to conceal their presence.</li><li>•They can provide a backdoor to threat actors giving them access to the PC, and allowing them to upload files, and install new software to be used in a DDoS attack.</li><li>•Special rootkit removal tools must be used to remove them, or a complete OS re-install may be required.</li></ul> |
| Spyware    | <ul style="list-style-type: none"><li>•Like adware but, used to gather information about the user and send to threat actors without the user's consent.</li><li>•Spyware can be a low threat, gathering browsing data, or it can be a high threat capturing personal and financial information.</li></ul>                                                                                                                                                                                                                                                                                                   |
| Worm       | <ul style="list-style-type: none"><li>•A worm is a self-replicating program that propagates automatically without user actions by exploiting vulnerabilities in legitimate software.</li><li>•It uses the network to search for other victims with the same vulnerability.</li><li>•The intent of a worm is usually to slow or disrupt network operations</li></ul>                                                                                                                                                                                                                                         |

# Social Engineering Attacks

## Social Engineering Attacks

---

# Social Engineering Attacks

Social engineering is an access attack that attempts to manipulate individuals into performing actions or divulging confidential information.

Social engineers often rely on people's willingness to be helpful. They also prey on people's weaknesses.

The Social Engineering Toolkit (SET) was designed to help white hat hackers and other network security professionals create social engineering attacks to test their own networks.

---

# Social Engineering Attacks

| Social Engineering Attack | Description                                                                                                                                                                                                        |
|---------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Pretexting                | A threat actor pretends to need personal or financial data to confirm the identity of the recipient.                                                                                                               |
| Phishing                  | A threat actor sends fraudulent email which is disguised as being from a legitimate, trusted source to trick the recipient into installing malware on their device, or to share personal or financial information. |
| Spear phishing            | A threat actor creates a targeted phishing attack tailored for a specific individual or organization.                                                                                                              |
| Spam                      | Also known as junk mail, this is unsolicited email which often contains harmful links, malware, or deceptive content.                                                                                              |
| Something for Something   | Sometimes called "Quid pro quo", this is when a threat actor requests personal information from a party in exchange for something such as a gift.                                                                  |
| Baiting                   | A threat actor leaves a malware infected flash drive in a public location. A victim finds the drive and unsuspectingly inserts it into their laptop, unintentionally installing malware.                           |
| Impersonation             | This type of attack is where a threat actor pretends to be someone they are not to gain the trust of a victim.                                                                                                     |
| Tailgating                | This is where a threat actor quickly follows an authorized person into a secure location to gain access to a secure area.                                                                                          |
| Shoulder surfing          | This is where a threat actor inconspicuously looks over someone's shoulder to steal their passwords or other information.                                                                                          |
| Dumpster diving           | This is where a threat actor rummages through trash bins to discover confidential documents                                                                                                                        |

# Social Engineering Attacks

Enterprises must educate their users about the risks of social engineering, and develop strategies to validate identities over the phone, via email, or in person.

Recommended practices should be followed by all users.



# Common Network Attacks

## Common Network Attacks

---

# Common Network Attacks

Networks are susceptible to the following types of attacks:

- **Reconnaissance Attacks.** Information gathering. Recon attacks precede access attacks or DoS attacks.
  - **Access Attacks.** Exploit known vulnerabilities in authentication services, FTP services, and web services. The purpose of these attacks is to gain entry to web accounts, confidential databases, and other sensitive information. Even escalate access privileges to administrator status.
  - **DoS Attacks.** Creates some sort of interruption of network services to users, devices, or applications.
-



# Reconnaissance Attacks

| Technique                                   | Description                                                                                                                                                                                                                  |
|---------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Perform an information query of a target    | The threat actor is looking for initial information about a target. Various tools can be used, including the Google search, organizations website, whois, and more.                                                          |
| Initiate a ping sweep of the target network | The information query usually reveals the target's network address. The threat actor can now initiate a ping sweep to determine which IP addresses are active.                                                               |
| Initiate a port scan of active IP addresses | This is used to determine which ports or services are available. Examples of port scanners include Nmap, SuperScan, Angry IP Scanner, and NetScanTools.                                                                      |
| Run vulnerability scanners                  | This is to query the identified ports to determine the type and version of the application and operating system that is running on the host. Examples of tools include Nipper, Core Impact, Nessus, SAINT, and Open VAS.     |
| Run exploitation tools                      | The threat actor now attempts to discover vulnerable services that can be exploited. A variety of vulnerability exploitation tools exist including Metasploit, Core Impact, Sqlmap, Social Engineer Toolkit, and Netsparker. |

# Access Attacks

- Password Attacks.
  - Spoofing Attacks
  - Trust exploitations
  - Port redirections
  - Man-in-the-middle attacks
  - Buffer overflow attacks
-

# DoS and DDoS Attacks

- DoS attacks are a major risk because they interrupt communication and cause significant loss of time and money. These attacks are relatively simple to conduct, even by an unskilled threat actor.
  - Distributed DoS Attack (DDoS) is similar to a DoS attack, but it originates from multiple, coordinated sources.
-

# DoS and DDoS Attacks

There are two major types of DoS attacks:

- **Overwhelming Quantity of Traffic.** The threat actor sends an enormous quantity of data at a rate that the network, host, or application cannot handle. This causes transmission and response times to slow down. It can also crash a device or service.
  - **Maliciously Formatted Packets.** The threat actor sends a maliciously formatted packet to a host or application and the receiver is unable to handle it. This causes the receiving device to run very slowly or crash.
-

# IP Vulnerabilities and Threats

## IP Vulnerabilities and Threats

---

# IPv4 and IPv6

IP does not validate whether the source IP address contained in a packet actually came from that source. For this reason, threat actors can send packets using a spoofed source IP address.

| IP Attack Techniques                 | Description                                                                                                                                                                                                                                                |
|--------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| ICMP attacks                         | Threat actors use Internet Control Message Protocol (ICMP) echo packets (pings) to discover subnets and hosts on a protected network, to generate DoS flood attacks, and to alter host routing tables.                                                     |
| Amplification and reflection attacks | Threat actors attempt to prevent legitimate users from accessing information or services using DoS and DDoS attacks.                                                                                                                                       |
| Address spoofing attacks             | Threat actors spoof the source IP address in an IP packet to perform blind spoofing or non-blind spoofing.                                                                                                                                                 |
| Man-in-the-middle attack (MITM)      | Threat actors position themselves between a source and destination to transparently monitor, capture, and control the communication. They could eavesdrop by inspecting captured packets, or alter packets and forward them to their original destination. |
| Session hijacking                    | Threat actors gain access to the physical network, and then use an MITM attack to hijack a session                                                                                                                                                         |

# ICMP Attacks

Threat actors use ICMP for reconnaissance and scanning attacks. They can launch information-gathering attacks to map out a network topology, discover which hosts are active (reachable), identify the host operating system (OS fingerprinting), and determine the state of a firewall. Threat actors also use ICMP for DoS attacks

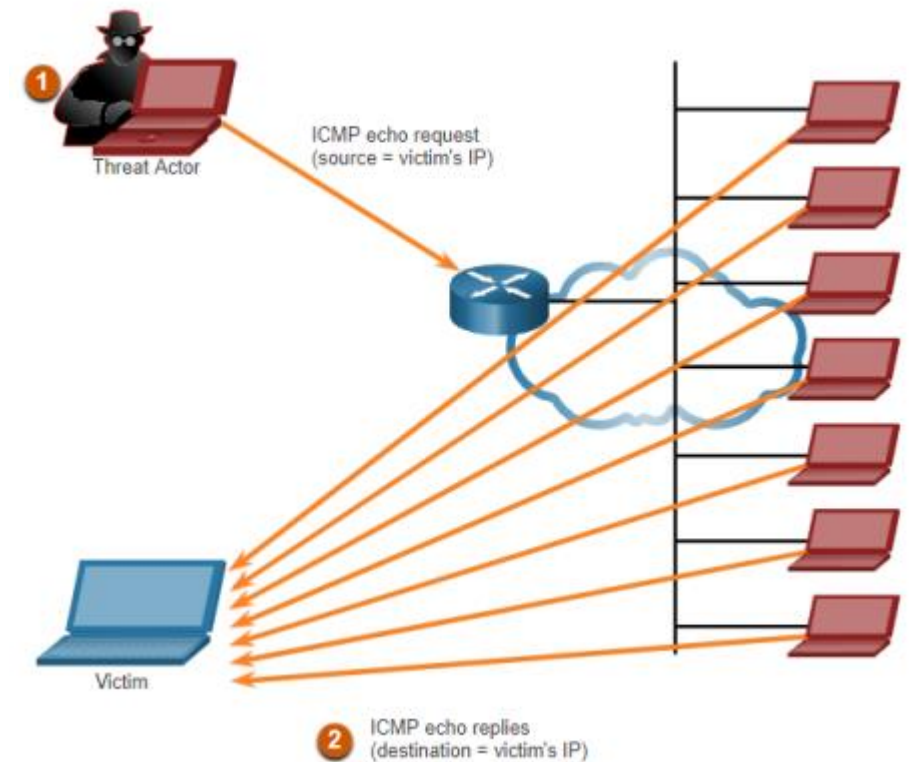
| ICMP Messages used by Hackers    | Description                                                                                                        |
|----------------------------------|--------------------------------------------------------------------------------------------------------------------|
| ICMP echo request and echo reply | This is used to perform host verification and DoS attacks.                                                         |
| ICMP unreachable                 | This is used to perform network reconnaissance and scanning attacks.                                               |
| ICMP mask reply                  | This is used to map an internal IP network.                                                                        |
| ICMP redirects                   | This is used to lure a target host into sending all traffic through a compromised device and create a MITM attack. |
| ICMP router discovery            | This is used to inject bogus route entries into the routing table of a target host.                                |

---

# Amplification and Reflection Attacks

Threat actors often use amplification and reflection techniques to create DoS attacks. The example in the figure illustrates a Smurf attack is used to overwhelm a target host.

Newer forms of amplification and reflection attacks such as DNS-based reflection and amplification attacks and Network Time Protocol (NTP) amplification attacks are now being used.





# Address Spoofing Attacks

IP address spoofing attacks occur when a threat actor creates packets with false source IP address information to either hide the identity of the sender, or to pose as another legitimate user. Spoofing is usually incorporated into another attack such as a Smurf attack.

Spoofing attacks can be non-blind or blind:

- **Non-blind spoofing.** The threat actor can see the traffic that is being sent between the host and the target. Non-blind spoofing determines the state of a firewall and sequence-number prediction. It can also hijack an authorized session.
- **Blind spoofing.** The threat actor cannot see the traffic that is being sent between the host and the target. Blind spoofing is used in DoS attacks.

MAC address spoofing attacks are used when threat actors have access to the internal network. Threat actors alter the MAC address of their host to match another known MAC address of a target host.

---

# TCP and UDP Vulnerabilities

## TCP and UDP Vulnerabilities

---

# TCP Segment Header

TCP segment information appears immediately after the IP header.

There are the six control bits of the TCP segment:

**URG.** Urgent pointer field significant

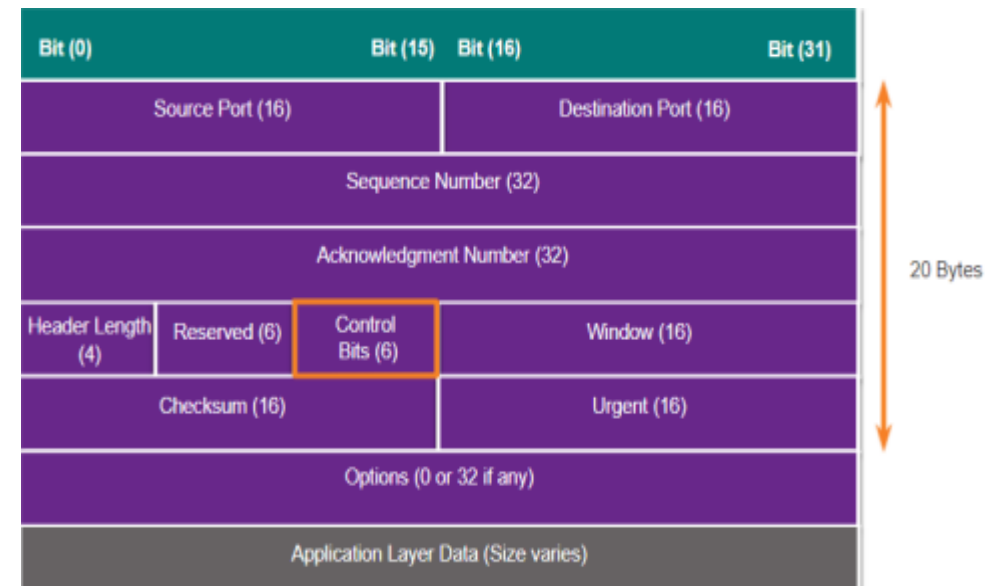
**ACK.** Acknowledgment field significant

**PSH.** Push function

**RST.** Reset the connection

**SYN.** Synchronize sequence numbers

**FIN.** No more data from sender

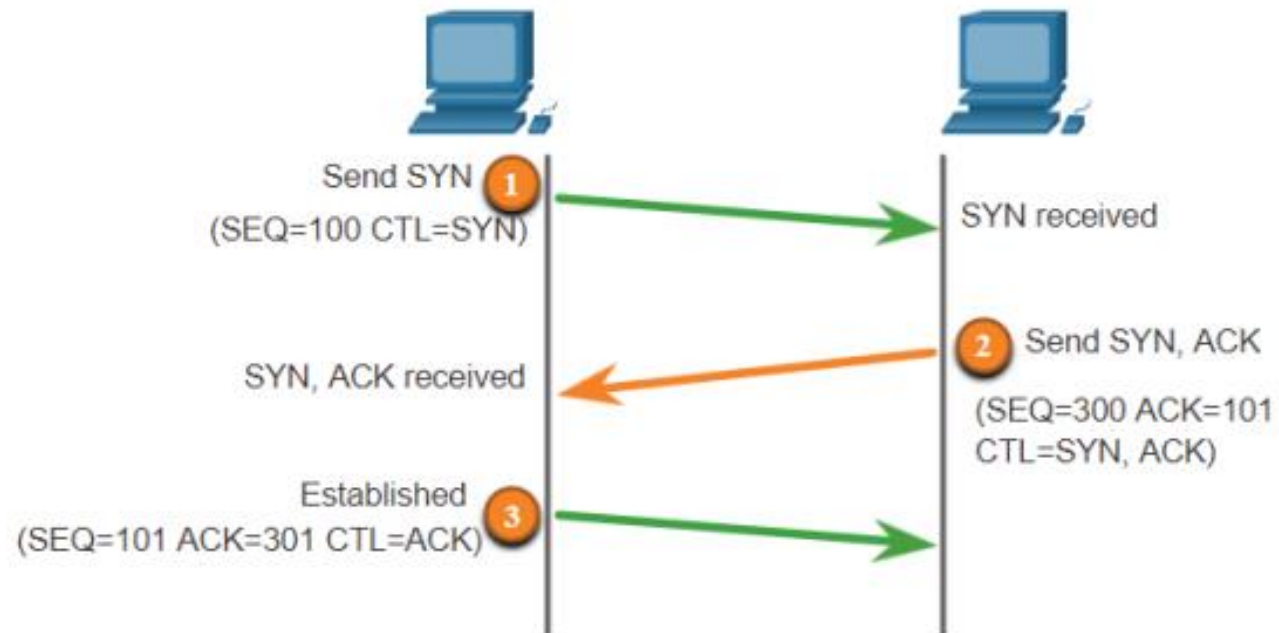


# TCP Services

TCP provides these services:

- **Reliable delivery.** TCP incorporates acknowledgments to guarantee delivery. If a timely **acknowledgment** is not received, the sender retransmits the data. Requiring acknowledgments of received data can cause substantial delays. Examples of application layer protocols that make use of TCP reliability include HTTP, SSL/TLS, FTP, DNS, etc.
  - **Flow control (Sliding Window).** TCP implements flow control to address this issue. Rather than acknowledge one segment at a time, multiple segments can be acknowledged with a single acknowledgment segment.
  - **Stateful communication.** TCP stateful communication between two parties occurs during the TCP **three-way handshake**.
-

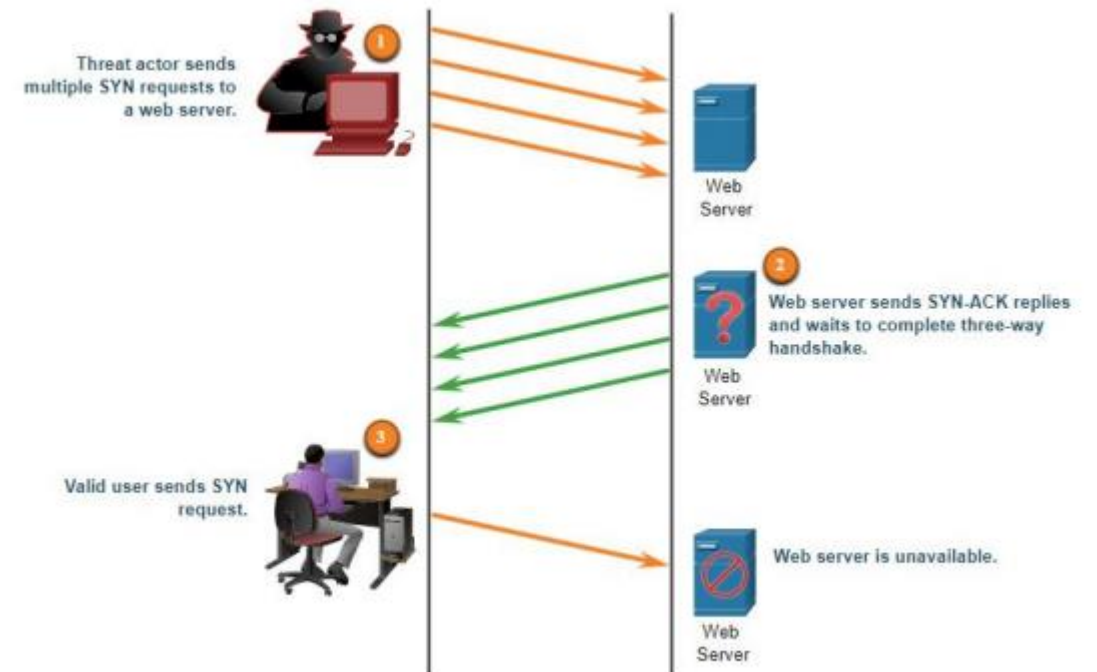
# TCP connection: Three-Way Handshake



# TCP Attacks

## TCP SYN Flood Attack

1. The threat actor sends multiple SYN requests to a webserver.
2. The web server replies with SYN-ACKs for each SYN request and waits to complete the three-way handshake. The threat actor does not respond to the SYN-ACKs.
3. A valid user cannot access the web server because the web server has too many halfopened TCP connections



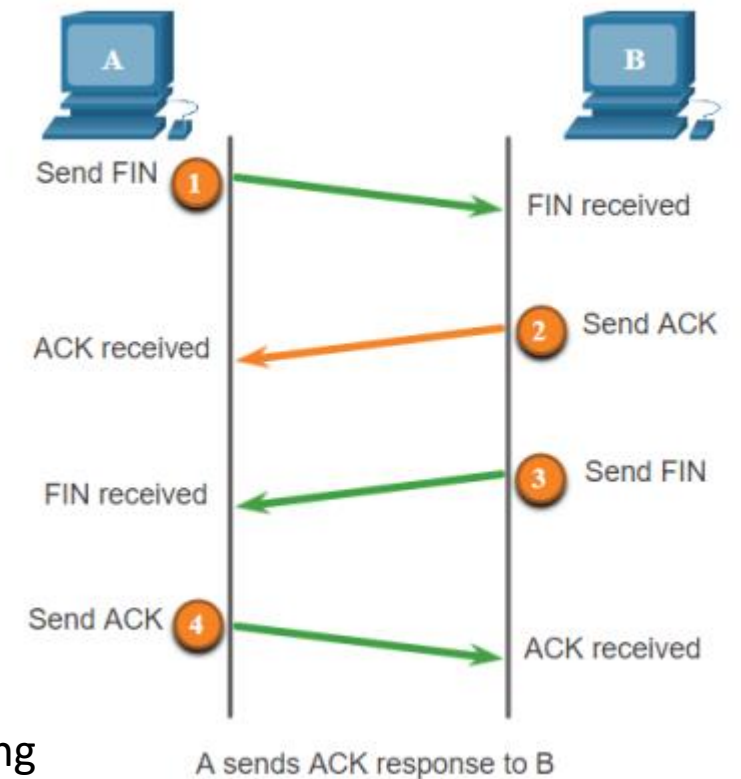
# TCP Attacks

## TCP Reset Attack

Terminating a TCP session uses the following four-way exchange process:

1. When the client has no more data to send in the stream, it sends a segment with the FIN flag set.
2. The server sends an ACK to acknowledge the receipt of the FIN to terminate the session from client to server.
3. The server sends a FIN to the client to terminate the server-to-client session.
4. The client responds with an ACK to acknowledge the FIN from the server.

A threat actor could do a TCP reset attack and send a spoofed packet containing a TCP RST to one or both endpoints.



# TCP Attacks

## TCP session hijacking

Although difficult to conduct, a threat actor takes over an already-authenticated host as it communicates with the target. The threat actor must spoof the IP address of one host, predict the next sequence number, and send an ACK to the other host. If successful, the threat actor could send, but not receive, data from the target device.

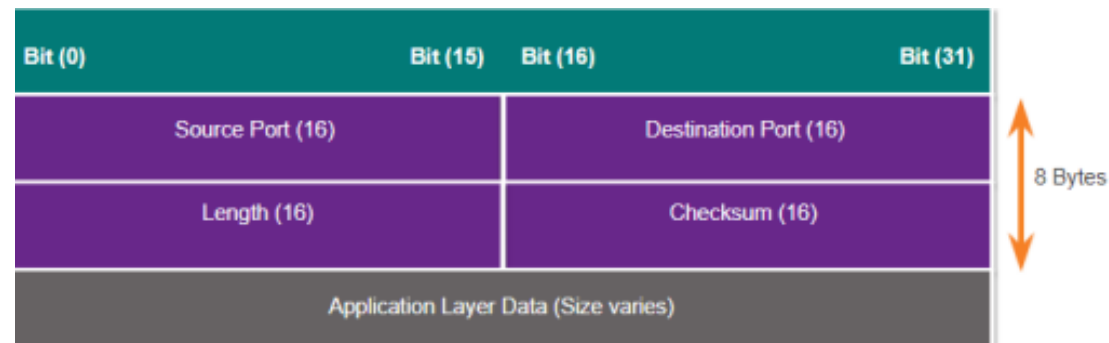
---



# UDP Segment Header and Operation

**UDP** is commonly used by DNS, TFTP, NFS, and SNMP. It is also used with real-time applications such as media streaming or VoIP.

**UDP** is a connectionless transport layer protocol. It has much lower overhead than TCP because it is not connection-oriented and does not offer the sophisticated retransmission, sequencing, and flow control mechanisms that provide reliability.



# UDP Attacks

## UDP Flood Attacks

The low overhead of UDP makes it very desirable for protocols that make simple request and reply transactions.

UDP is not protected by any encryption, it is not available by default. The lack of encryption means that anyone can see the traffic, change it, and send it on to its destination.

**UDP Flood Attacks:** The threat actor uses a tool like UDP Unicorn or Low Orbit Ion Cannon to send a flood of UDP packets, often from a spoofed host. The program will sweep through all the known ports trying to find closed ports causing the server to reply with an ICMP port unreachable message. Because there are many closed ports on the server, this creates a lot of traffic on the segment. The result is very similar to a DoS attack.

---

# IP Services and Vulnerabilities

## IP Services and Vulnerabilities

---

# ARP Vulnerabilities

Hosts broadcast an ARP Request to other hosts on the segment to determine the MAC address of a host with a particular IP address. The host with the matching IP address in the ARP Request sends an ARP Reply.

Any client can send an unsolicited ARP Reply called a “gratuitous ARP.” When a host sends a gratuitous ARP, other hosts on the subnet store the MAC address and IP address contained in the gratuitous ARP in their ARP tables.

This feature of ARP also means that any host can claim to be the owner of any IP or MAC. A threat actor can poison the ARP cache of devices on the local network, creating an MITM attack to redirect traffic.

---

# ARP Cache Poisoning

The **ARP poisoning attack** can be passive or active. **Passive** ARP poisoning is where threat actors steal confidential information. **Active** ARP poisoning is where threat actors modify data in transit or inject malicious data.

1. PC-A requires the MAC address of its default gateway (R1); therefore, it sends an ARP Request for the MAC address of 192.168.10.1.
  2. R1 updates its ARP cache with the IP and MAC addresses of PC-A. R1 sends an ARP Reply to PC-A, which then updates its ARP cache with the IP and MAC addresses of R1.
  3. The threat actor sends two spoofed gratuitous ARP Replies using its own MAC address for the indicated destination IP addresses. PC-A updates its ARP cache pointing to the threat actor's host MAC address. R1 also updates its ARP cache with the IP address of PC-A pointing to the threat actor's MAC address.
-

# DNS Attacks

The **Domain Name Service (DNS)** protocol defines an automated service that matches resource names, such as `www.cisco.com`, with the required numeric network address (IPv4 or IPv6). It includes the format for queries, responses, and data. It uses resource records (RR) to identify the type of DNS response

DNS attacks include the following:

- DNS open resolver attacks
  - DNS stealth attacks
  - DNS domain shadowing attacks
  - DNS tunneling attacks
-

# DNS Attacks

## DNS Open Resolver Attacks

A DNS open resolver answers queries from clients outside of its administrative domain.

| DNS Resolver Vulnerabilities             | Description                                                                                                                                                                                                                                                                                                                                      |
|------------------------------------------|--------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| DNS cache poisoning attacks              | Threat actors send spoofed, falsified record resource (RR) information to a DNS resolver to redirect users from legitimate sites to malicious sites. DNS cache poisoning attacks can all be used to inform the DNS resolver to use a malicious name server that is providing RR information for malicious activities.                            |
| DNS amplification and reflection attacks | Threat actors use DoS or DDoS attacks on DNS open resolvers to increase the volume of attacks and to hide the true source of an attack. Threat actors send DNS messages to the open resolvers using the IP address of a target host. These attacks are possible because the open resolver will respond to queries from anyone asking a question. |
| DNS resource utilization attacks         | A DoS attack that consumes the resources of the DNS open resolvers. This DoS attack consumes all the available resources to negatively affect the operations of the DNS open resolver. The impact of this DoS attack may require the DNS open resolver to be rebooted or services to be stopped and restarted.                                   |

# DNS Attacks

## DNS Stealth Attacks

A DNS Stealth Attacks are used to hide threat actors identity.

| DNS Stealth Techniques       | Description                                                                                                                                                                                                                                                                                                       |
|------------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Fast Flux                    | Threat actors use this technique to hide their phishing and malware delivery sites behind a quickly-changing network of compromised DNS hosts. The DNS IP addresses are continuously changed within minutes. Botnets often employ Fast Flux techniques to effectively hide malicious servers from being detected. |
| Double IP Flux               | Threat actors use this technique to rapidly change the hostname to IP address mappings and to also change the authoritative name server. This increases the difficulty of identifying the source of the attack.                                                                                                   |
| Domain Generation Algorithms | Threat actors use this technique in malware to randomly generate domain names that can then be used as rendezvous points to their command and control (C&C) servers.                                                                                                                                              |



# DNS Attacks

## DNS Domain Shadowing Attacks

Domain shadowing involves the threat actor gathering domain account credentials in order to silently create multiple sub-domains to be used during the attacks. These subdomains typically point to malicious servers without alerting the actual owner of the parent domain.

## DNS Tunneling

Threat actors who use DNS tunneling place non-DNS traffic within DNS traffic. This method is often used as a workaround of security solutions when a threat actor wishes to communicate with bots inside a protected network, or exfiltrate data from the organization.

To stop DNS tunneling, the network administrator must use a filter that inspects DNS traffic. Pay close attention to DNS queries that are longer than average, or those that have a suspicious domain name.

---

# DHCP Attacks

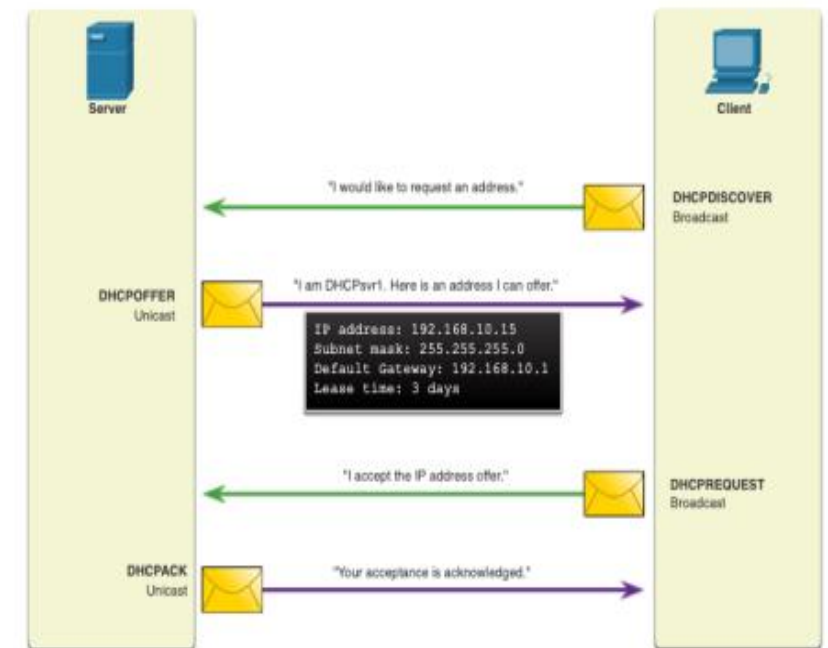
DHCP servers dynamically provide IP configuration information to clients.

In the figure, a client broadcasts a DHCP discover message.

The DHCP responds with a unicast offer that includes addressing information the client can use.

The client broadcasts a DHCP request to tell the server that the client accepts the offer.

The server responds with a unicast acknowledgment accepting the request



# DHCP Attacks

## DHCP spoofing attack

A DHCP spoofing attack occurs when a rogue DHCP server is connected to the network and provides false IP configuration parameters to legitimate clients. A rogue server can provide a variety of misleading information:

- **Wrong default gateway.** Threat actor provides an invalid gateway, or the IP address of its host to create a MITM attack. This may go entirely undetected as the intruder intercepts the data flow through the network.
  - **Wrong DNS server.** Threat actor provides an incorrect DNS server address pointing the user to a malicious website.
  - **Wrong IP address.** Threat actor provides an invalid IP address, invalid default gateway IP address, or both. The threat actor then creates a DoS attack on the DHCP client.
-

# Network Security Best Practices

## Network Security Best Practices

---

# Network Security Best Practices

Network security consists of protecting information and information systems from unauthorized access, use, disclosure, disruption, modification, or destruction.

Most organizations follow the CIA information security triad:

- **Confidentiality.** Only authorized individuals, entities, or processes can access sensitive information. It may require using cryptographic encryption algorithms such as AES to encrypt and decrypt data.
  - **Integrity.** Refers to protecting data from unauthorized alteration. It requires the use of cryptographic hashing algorithms such as SHA.
  - **Availability.** Authorized users must have uninterrupted access to important resources and data. It requires implementing redundant services, gateways, and links
-

# The Defense-in-Depth Approach

The Defense-in-Depth Approach requires a combination of networking devices and services working together. To ensure secure communications across both public and private networks, you must secure devices including routers, switches, servers, and hosts.

Several security devices and services:

- VPN
- ASA Firewall
- IPS
- ESA/WSA
- AAA Server

You must also secure data as it travels across various links. You must also secure data as it travels across various links.

---

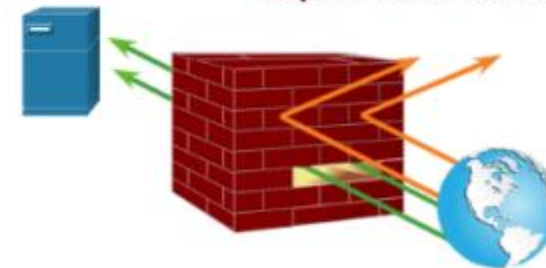
# Firewalls

A firewall is a network security device that monitors incoming and outgoing network traffic and decides whether to allow or block specific traffic based on a defined set of security rules.

Firewalls have been a first line of defense in network security for over 25 years. They establish a barrier between secured and controlled internal networks, that can be trusted, and untrusted outside networks, such as the Internet.

A firewall can be hardware, software, software-as-a service (SaaS), public cloud, or private cloud (virtual).

|                                                                   |                                                                                                   |
|-------------------------------------------------------------------|---------------------------------------------------------------------------------------------------|
| <b>Allow</b> traffic from any external address to the web server. | <b>Deny</b> all inbound traffic with network addresses matching internal-registered IP addresses. |
| <b>Allow</b> traffic to FTP server.                               | <b>Deny</b> all inbound traffic to server from external addresses.                                |
| <b>Allow</b> traffic to SMTP server.                              | <b>Deny</b> all inbound ICMP echo request traffic.                                                |
| <b>Allow</b> traffic to internal IMAP server.                     | <b>Deny</b> all inbound MS Active Directory queries.                                              |
|                                                                   | <b>Deny</b> all inbound traffic to MS SQL server queries.                                         |
|                                                                   | <b>Deny</b> all MS Domain Local Broadcasts.                                                       |



# Intrusion Prevention System (IPS)

An intrusion prevention system (IPS) is technology that detects patterns in network traffic that are considered malicious activity and act over the traffic.

Unlike an IPS, an Intrusion Detection System (IDS) can detect but not respond to malicious activity.

An IPS tool sits inline (i.e., directly in the path of network traffic) and often behind a firewall, where it can scan and analyze incoming data that has made it inside the perimeter.



# Intrusion Prevention System (IPS)

The following are three common IPS methods for recognizing threats:

1. **Signature-based detection.** With this technique, the IPS scans for attack signatures of known network threats.
2. **Anomaly-based detection.** Using this technique, the IPS searches for unexpected network behavior.
3. **Policy-based detection.** This technique involves looking for activity that breaks enterprise security policies, which administrators establish in advance.

# Intrusion Prevention System (IPS)

When an IPS detects threats, it may take the following actions:

- Drop suspicious network packets.
- Block suspicious traffic.
- Send alerts to security administrators.
- Reconfigure firewalls.
- Reset network connections.

# Content Security Devices

The Cisco Email Security Appliance (ESA) is a special device designed to monitor Simple Mail Transfer Protocol (SMTP).

The Cisco Web Security Appliance (WSA) is a mitigation technology for web-based threats. WSA provides complete control over how users access the internet. The WSA can perform blacklisting of URLs, URL-filtering, malware scanning, URL categorization, web application filtering, and encryption and decryption of web traffic

---

A blue banner with a wavy, ribbon-like shape, featuring a slight gradient and a dark blue shadow along its bottom edge.

Cryptography

Cryptography

---

# Cryptography

**Cryptography.** is the process of hiding or coding information so that only the person a message was intended for can read it. The art of cryptography has been used to code messages for thousands of years and continues to be used in bank cards, computer passwords, and ecommerce.

**Encryption** is a way to render data unreadable to an unauthorized party. Information is converted to ciphertext. Only authorized people who have the key can decipher the code and access the original plaintext information.

Modern cryptography techniques include algorithms and ciphers that enable the encryption and decryption of information, such as 128-bit and 256-bit encryption keys. Modern Ciphers, such as the Advanced Encryption Standard (AES), are considered virtually unbreakable.

# Securing Communications

Four elements to take care for secure communications:

**Data Integrity.** Cryptography ensures information is not altered while in storage or during transit between the sender and the intended recipient. For example, digital signatures can detect forgery or tampering in software distribution and financial transactions.

**Origin Authentication.** Guarantees that the message is not a forgery and does come from whom it states. Many modern networks ensure authentication with protocols, such as hash message authentication code (HMAC)

# Securing Communications

Cont'd

**Data Confidentiality.** - Cryptography ensures confidentiality by encrypting sent messages using an algorithm with a key only known to the sender and recipient. A common example of this is WhatsApp, which encrypts conversations between people to ensure they cannot be hacked or intercepted.

**Data Non-Repudiation.** Cryptography confirms accountability and responsibility from the sender of a message, which means they cannot later deny their intentions when they created or transmitted information. Digital signatures are a good example of this, as they ensure a sender cannot claim a message, contract, or document they created to be fraudulent. Furthermore, in email nonrepudiation, email tracking makes sure the sender cannot deny sending a message and a recipient cannot deny receiving it.

# Data Integrity

**Hash** functions ensure that data integrity is maintained in the encryption and decryption phases of cryptography. It is also used in databases so that items can be retrieved more quickly.

**Hashing** is the process of taking a key and mapping it to a specific value, which is the hash or hash value. The hash value and signature are sent to the receiver, who uses the hash function to generate the hash value and compare it with the one they received in the message.

While hashing can be used to detect accidental changes, it cannot be used to guard against deliberate changes. This means that anyone can compute a hash for any data, if they have the correct hash function.

Therefore, hashing is vulnerable to man-in-the-middle attacks and does not provide security to transmitted data.



# Data Integrity

## Hash Functions

There are three well-known hash functions:

- **MD5 (Message Digest 5)** with 128-bit Digest: MD5 is a one-way function that produces a 128-bit hashed message. MD5 is a legacy algorithm that should only be used when no better alternatives are available. Use SHA-2 instead.
  - **SHA (Secure Hashing Algorithm)**: SHA-1 is very similar to the MD5 hash functions. SHA-1 creates a 160-bit hashed message and is slightly slower than MD5. SHA-1 has known flaws and is a legacy algorithm. Use SHA-2 when possible.
  - **SHA-2**: This includes SHA-224 (224 bit), SHA-256 (256 bit), SHA-384 (384 bit), and SHA-512 (512 bit). SHA-256, SHA-384, and SHA-512 are next-generation algorithms and should be used whenever possible.
-

# Origin Authentication

**Hash-based Message Authentication Code (HMAC)** is a mechanism for message authentication using cryptographic hash functions.

- An HMAC is calculated using any cryptographic algorithm that combines a cryptographic hash function (MD5 or SHAs) with a secret key.
  - Only parties who have access to that secret key can compute the digest of an HMAC function.
  - This is intended to defeat man-in-the-middle attacks and provides authentication of the data origin.
-

# Data Confidentiality

There are two classes of encryption used to provide data confidentiality. These two classes differ in how they use keys.

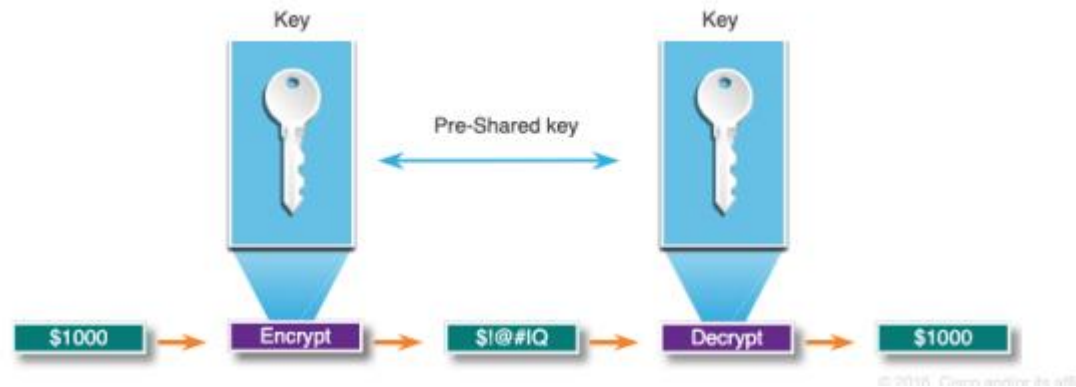
**Symmetric Encryption.** In this simple encryption method, **only one secret key** is used to both cipher and decipher information. The main drawback is that both parties need to have the key used to encrypt the data before they can decrypt it. Symmetric encryption algorithms include AES-128, AES-192, and AES-256. Because it is less complex and executes faster, symmetric encryption is the preferred method for transmitting data in bulk.

**Asymmetric Encryption** uses **two different but related keys** to encrypt and decrypt data. One key is secret and one key is public. The public key is used to encrypt data, and the private key is used to decrypt (and vice versa). Security of the public key is not needed because it is publicly available and can be shared over the internet.

# Symmetric Encryption

Symmetric encryption algorithms are commonly used with VPN traffic because they use less CPU resources than asymmetric encryption algorithms.

When using symmetric encryption algorithms, the longer the key, the longer it will take for someone to discover the key. To ensure that the encryption is safe, use a minimum key length of 128 bits.



# Symmetric Encryption

| Symmetric Encryption Algorithms                | Description                                                                                                                                                                                                                                                                                          |
|------------------------------------------------|------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Data Encryption Algorithm (DES)                | This is a legacy symmetric encryption algorithm. It can be used in stream cipher mode but usually operates in block mode by encrypting data in 64-bit block size. A stream cipher encrypts one byte or one bit at a time.                                                                            |
| 3DES (Triple DES)                              | This is a newer version of DES, but it repeats the DES algorithm process three times. It is considered very trustworthy when implemented using very short key lifetimes.                                                                                                                             |
| Advanced Encryption Standard (AES)             | AES is a secure and more efficient algorithm than 3DES. It is a popular and recommended symmetric encryption algorithm. It offers nine combinations of key and block length by using a variable key length of 128-, 192-, or 256-bit key to encrypt data blocks that are 128, 192, or 256 bits long. |
| Software-Optimized Encryption Algorithm (SEAL) | SEAL is a faster alternative symmetric encryption algorithm to DES, 3DES, and AES. It uses a 160-bit encryption key and has a lower impact on the CPU compared to other software-based algorithms.                                                                                                   |
| Rivest ciphers (RC) series algorithms          | This algorithm was developed by Ron Rivest. Several variations have been developed, but RC4 is the most prevalent in use. RC4 is a stream cipher and is used to secure web traffic in SSL and TLS.                                                                                                   |

# Asymmetric Encryption

Asymmetric encryption presents a much stronger option for ensuring the security of information transmitted over the internet. Websites are secured using Secure Socket Layer (SSL) or Transport Layer Security (TLS) certificates. A query to a web server sends back a copy of the digital certificate, and a public key can be extracted from that certificate, while the private key stays private.

Because neither party has a shared secret, very long key lengths must be used. Asymmetric encryption can use key lengths between 512 to 4,096 bits. Key lengths greater than or equal to 1,024 bits can be trusted while shorter key lengths are considered unreliable.

Because they are slow, asymmetric algorithms are typically used in low-volume cryptographic mechanisms, such as digital signatures and key exchange.

# Asymmetric Encryption

Examples of protocols that use asymmetric key algorithms include:

**Internet Key Exchange (IKE).** This is a fundamental component of IPsec VPNs.

**Secure Socket Layer (SSL).** This is now implemented as IETF standard Transport Layer Security (TLS).

**Secure Shell (SSH).** This protocol provides a secure remote access connection to network devices.

**Pretty Good Privacy (PGP).** This computer program provides cryptographic privacy and authentication. It is often used to increase the security of email communications.

---



# Asymmetric Encryption

| Asymmetric Encryption Algorithm                                        | Key Length                  | Description                                                                                                                                                                                                                                                                                                                                           |
|------------------------------------------------------------------------|-----------------------------|-------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------------|
| Diffie-Hellman (DH)                                                    | 512, 1024, 2048, 3072, 4096 | The Diffie-Hellman algorithm allows two parties to agree on a key that they can use to encrypt messages they want to send to each other. The security of this algorithm depends on the assumption that it is easy to raise a number to a certain power, but difficult to compute which power was used given the number and the outcome.               |
| Digital Signature Standard (DSS) and Digital Signature Algorithm (DSA) | 512 - 1024                  | DSS specifies DSA as the algorithm for digital signatures. DSA is a public key algorithm based on the ElGamal signature scheme. Signature creation speed is similar to RSA but is 10 to 40 times slower for verification.                                                                                                                             |
| Rivest, Shamir, and Adleman encryption algorithms (RSA)                | 512 to 2048                 | RSA is for public-key cryptography that is based on the current difficulty of factoring very large numbers. It is the first algorithm known to be suitable for signing as well as encryption. It is widely used in electronic commerce protocols and is believed to be secure given sufficiently long keys and the use of up-to-date implementations. |
| ElGamal                                                                | 512 - 1024                  | An asymmetric key encryption algorithm for public-key cryptography which is based on the Diffie-Hellman key agreement. A disadvantage of the ElGamal system is that the encrypted message becomes very big, about twice the size of the original message and for this reason it is only used for small messages such as secret keys.                  |
| Elliptical curve techniques                                            | 160                         | Elliptic curve cryptography can be used to adapt many cryptographic algorithms, such as Diffie-Hellman or ElGamal. The main advantage of elliptic curve cryptography is that the keys can be much smaller.                                                                                                                                            |



# Diffie-Hellman

**Diffie-Hellman (DH)** is an asymmetric mathematical algorithm where two computers generate an identical shared secret key without having communicated before. The new shared key is never actually exchanged between the sender and receiver.

Three examples of instances when DH is commonly used:

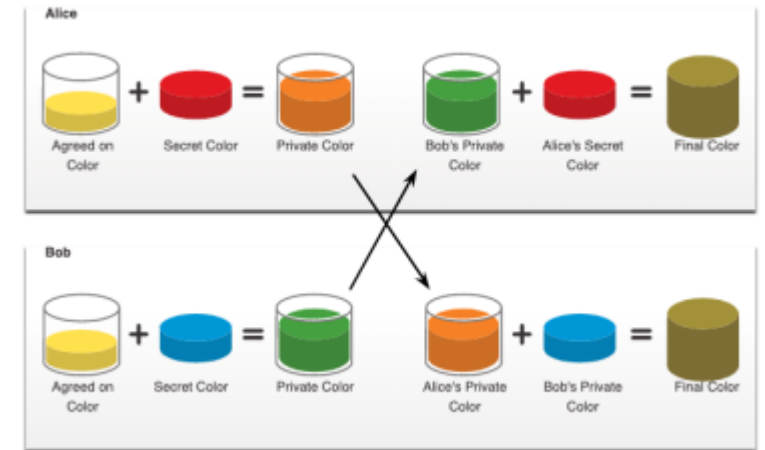
- Data is exchanged using an IPsec VPN.
  - Data is encrypted on the internet using either SSL or TLS.
  - SSH data is exchanged.
-

# Diffie-Hellman

## How Diffie-Hellman Works

The colors in the figure will be used instead of numbers to simplify the DH key agreement process. The DH key exchange begins with Alice and Bob agreeing on an arbitrary common color that does not need to be kept secret. The agreed upon color in our example is yellow.

Alice and Bob will each select a secret color. Alice chose red while Bob chose blue. These secret colors will never be shared with anyone. The secret color represents the chosen secret private key of each party.



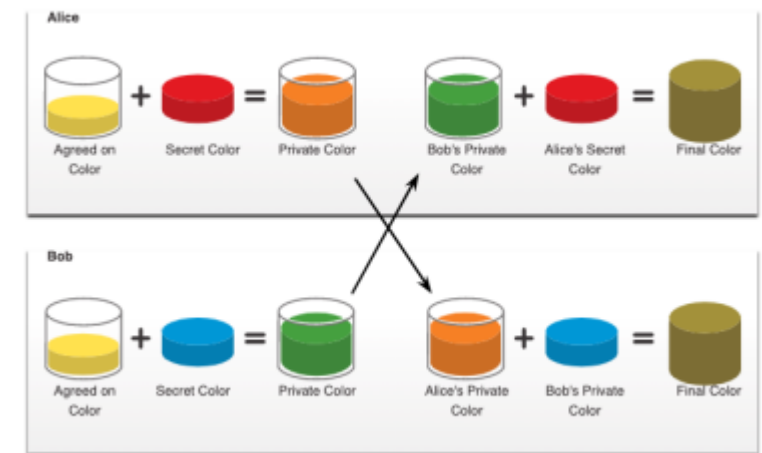
# Diffie-Hellman

Cont'd

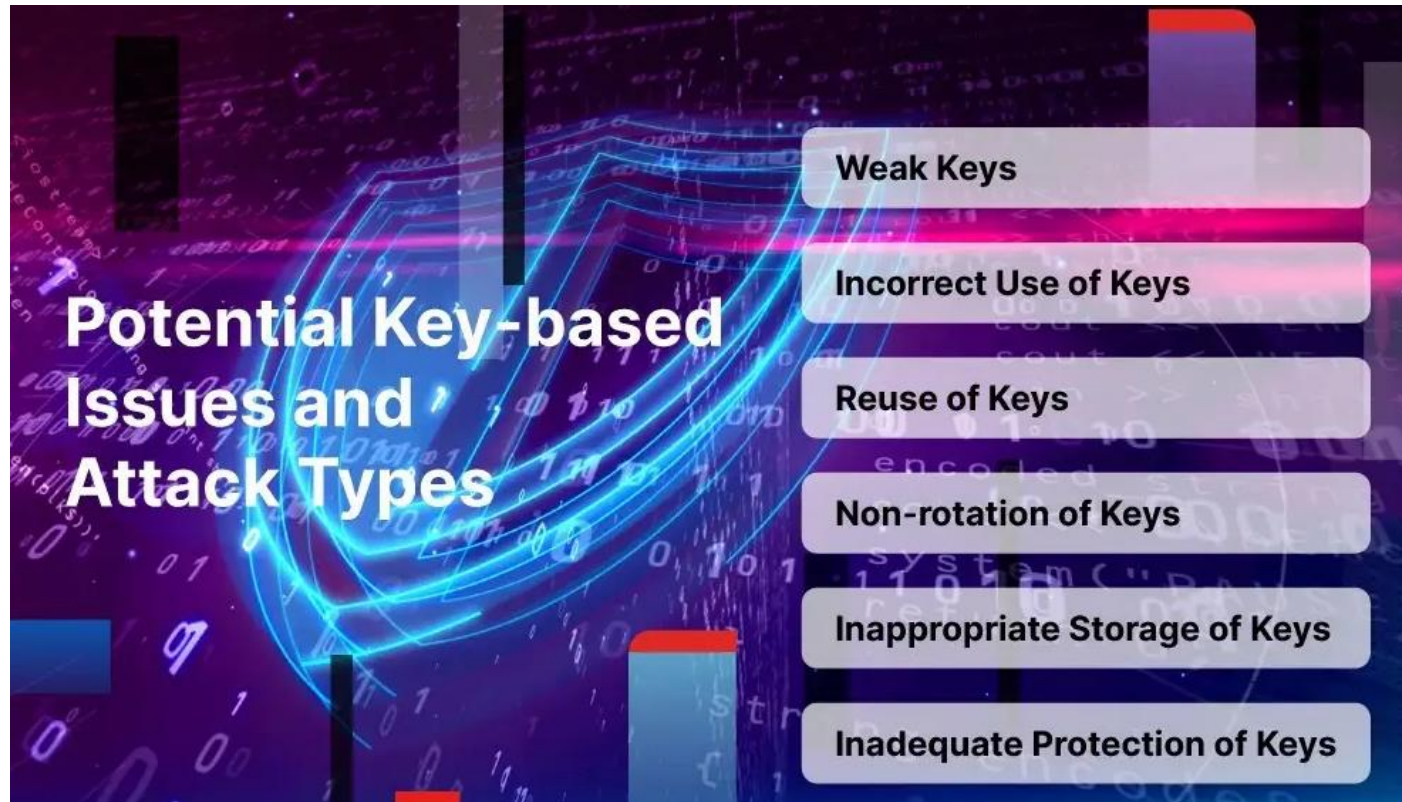
Alice and Bob now mix the shared common color (yellow) with their respective secret color to produce a private color. Therefore, Alice will mix the yellow with her red color to produce a private color of orange. Bob will mix the yellow and the blue to produce a private color of green.

Alice sends her private color (orange) to Bob and Bob sends his private color (green) to Alice.

Alice and Bob each mix the color they received with their own, original secret color (Red for Alice and blue for Bob.). The result is a final brown color mixture that is identical to the other's final color mixture. The brown color represents the resulting shared secret key between Bob and Alice.



# Key-Based Issues



# Encryption in the Cloud

**Cloud encryption** is a service offered by cloud storage providers in which data is first encrypted using algorithms before being pushed to a storage cloud. Customers of a cloud storage provider must be aware of and comfortable with the level of depth of the provider's policies and procedures for encryption and encryption key management.

Because encryption consumes more bandwidth, many cloud providers only offer basic encryption on a few database fields, such as passwords and account numbers. This is often not enough for some organizations. So they rely on a Bring Your Own Encryption (BYOE) model in which they use their own encryption software and manage their own encryption keys to ensure a level of cloud computing security they are comfortable with.

As an opposite approach, Encryption as a Service (EaaS) has emerged as a simple, pay-as-you-go service customers can purchase from a cloud provider, managing encryption themselves in a multi-tenant environment.

# End-to-End Encryption

End-to-end encryption (E2EE) ensures that only the two users communicating with one another can read the messages. Even the intermediary, such as the telecom or internet service provider, cannot decrypt the messages. E2EE is generally seen as the most secure way to communicate privately and securely online. Examples of E2EE in use include the WhatsApp service, which famously asserts that users' messages are secured with "locks."

A blue banner with a wavy, ribbon-like shape, featuring a subtle gradient and a slight shadow.

Thank You

Thank you

